Fileless Malware via Browser-to-System Execution

Hoe een browserinteractie leidt tot lokale fileless code execution

Wat is Fileless Malware?

Geen klassieke malware file

Geen binaire op schijf

PowerShell / LOLBins

Gebaseerd op bestaande tools

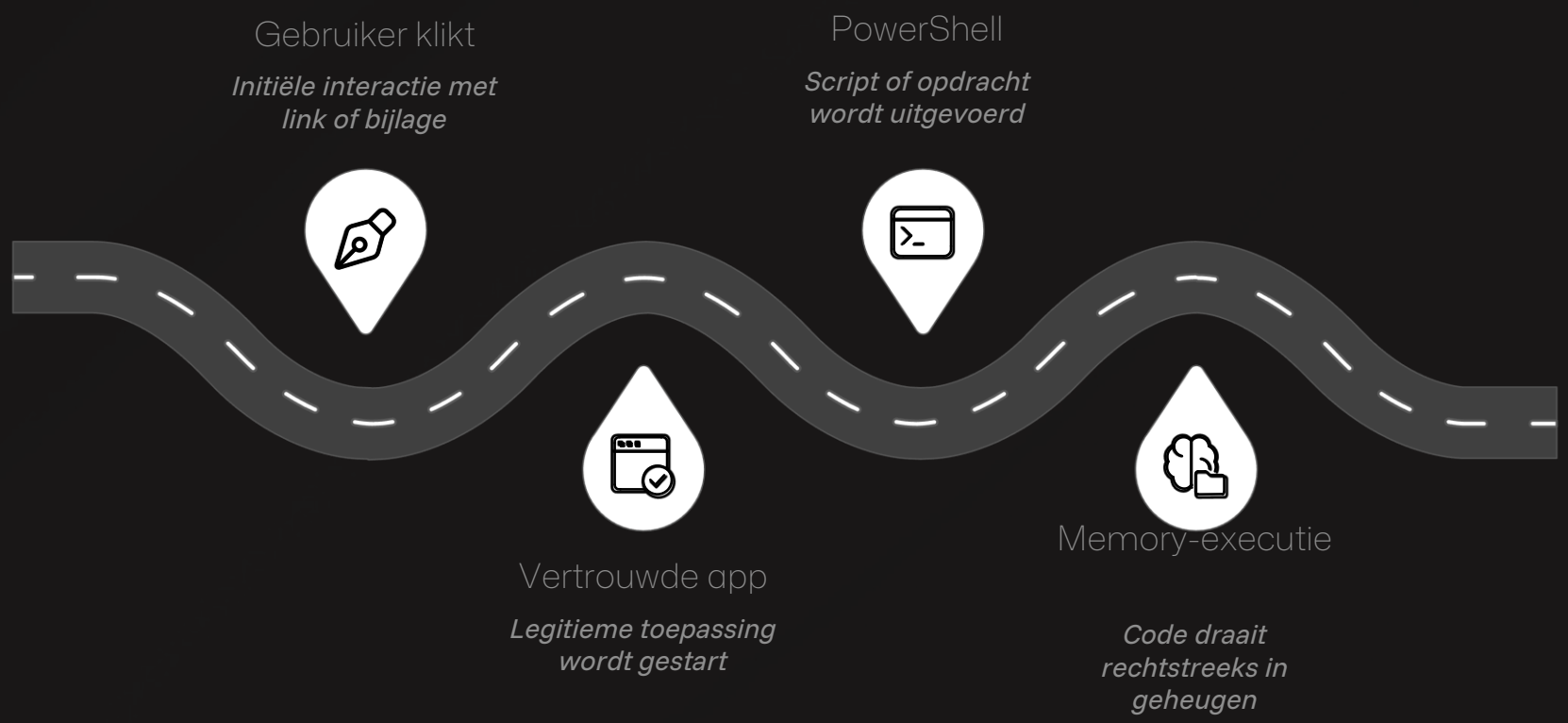
In-memory execution

Direct in RAM uitgevoerd

Moeilijker detecteerbaar

Ontsnapt standaard AV

De Attack Chain



Gebruiker klikt → vertrouwde applicatie → PowerShell → code in memory

Onze Exploit Flow

WordPress | m1jsdemo | Windows Handler | Electron App | PowerShell

WordPress Site

Phishing of compromitie

Electron App

Desktop app met protocol handler

PowerShell

In-memory code execution

Protocol Handlers & Electron

Windows Protocol Handler

URI-scheme koppelt browser naar desktop app

Electron Framework

Node.js + Chromium in één app

Realistisch Scenario

Gevestigde software wordt misbruikt

MITRE ATT&CK Mapping

T1204: User Execution

Gebruiker activeert malicieuze code

T1059.001: PowerShell

Command-line interface voor execution

T1095: TCP Command Channel

Outbound C2 communicatie

Live Demo

WordPress site openen

Geïntegreerde exploit pagina

Knop activeren

Browser trigger → Electron

PowerShell start

In-memory execution zichtbaar

Outbound connectie

Bevestiging via logging

Detectie Signatures

Event ID 4688

powershell.exe gestart door Electron

Wazuh / SIEM

Centralized logging & correlatie

Netstat monitoring

Onverwachte TCP connecties

Mitigaties

PowerShell logging

Transcriptie & script block logging

AppLocker

Whitelisting voor executie

EDR oplossingen

Real-time process monitoring

Outbound filtering

TCP-verbindingen beperken

Conclusie

Deze demo toont hoe legitieme technologieën misbruikt kunnen worden voor fileless execution, en hoe belangrijk monitoring en detectie zijn.